

SOP-004: Data Protection, Security, and Compliance Review

Document ID: SOP-SEC-004

Version: 3.1

Last Updated: May 2026

Owner: Example Corp — Information Security & Legal

Classification: Internal Use Only

1. PURPOSE

This SOP defines Example Corp's mandatory data protection, security, and regulatory compliance requirements that must be present in all partner contracts involving access to Example Corp systems or data. The review agent must verify these provisions are present and meet minimum standards.

2. DATA CLASSIFICATION AND HANDLING

2.1 Data Ownership (Non-Negotiable)

- All Example Corp data remains the **exclusive property of Example Corp** at all times
- Provider is a data processor only; never a data owner or controller
- Provider has no independent rights to use, sell, or license Example Corp data
- Data includes all derivatives, aggregations, and analytics produced from Example Corp data

2.2 Data Handling Requirements

Contracts must specify: - Data classification level (Public, Internal, Confidential, Restricted) - Permitted use limited to performing contracted services only - Prohibition on commingling with other clients' data - Geographic restrictions on data storage and processing (US-only unless approved)

3. SECURITY REQUIREMENTS

3.1 Mandatory Security Standards

Provider must certify compliance with at least one: - SOC 2 Type II (current, within 12 months) - ISO 27001 certification - FedRAMP authorization (for government-adjacent work)

3.2 Technical Security Controls (Required)

Contracts must require: - Encryption at rest (AES-256 minimum) - Encryption in transit (TLS 1.2 minimum) - Multi-factor authentication for all access to Example Corp data - Role-based access control with least-privilege principle - Quarterly access reviews - Annual penetration testing with results shared to Example Corp

3.3 Security Red Flags — Flag as CRITICAL

- “Commercially reasonable” security without specific standards
 - No encryption requirements specified
 - No certification or audit requirements
 - Provider self-assessment as sole security validation
 - No penetration testing or vulnerability scanning requirements
-

4. DATA BREACH AND INCIDENT RESPONSE

4.1 Breach Notification Timeline (Mandatory)

- **Maximum 72 hours** from discovery to notification of Example Corp
- Measured in clock hours, not business days
- Initial notification may be preliminary; detailed report within 5 business days

4.2 Breach Notification Contents (Required)

Initial notification must include: - Nature and scope of the breach - Types of data affected - Number of records potentially compromised - Immediate containment actions taken - Point of contact for ongoing communication

4.3 Breach Response Obligations

- Provider bears cost of breach response, notification, and remediation
- Credit monitoring for affected individuals (minimum 24 months)
- Forensic investigation by mutually agreed third party
- Root cause analysis report within 30 days
- Remediation plan with implementation timeline

4.4 Breach Notification Red Flags — Flag as CRITICAL

- Notification period exceeding **72 hours**
 - Notification measured in “business days” rather than clock hours
 - No defined notification timeline
 - No specification of notification contents
 - Provider not bearing breach response costs
-

5. DATA RETENTION AND DESTRUCTION

5.1 Retention Requirements

- Data retained only for duration necessary to perform services
- Maximum retention: **30 days post-termination** for transition purposes
- Retention beyond 30 days requires separate written approval from Example Corp CISO

5.2 Data Destruction Requirements

Upon termination or request: - All Example Corp data destroyed within **30 days** - Destruction must follow NIST 800-88 guidelines - Written certification of destruction provided to Example Corp - Destruction includes all copies, backups, and archives - No exceptions for “business purposes” or “legal hold” without Example Corp consent

5.3 Retention/Destruction Red Flags — Flag as CRITICAL

- Indefinite retention rights
 - Provider retaining data for “business purposes” after termination
 - No destruction certification requirement
 - No destruction timeline specified
 - Retention without Example Corp’s ongoing consent
-

6. REGULATORY COMPLIANCE

6.1 Compliance Requirements

Contracts must address applicable regulations: - **GDPR** (if EU data subjects involved) - **CCPA/CPRA** (California resident data) - **HIPAA** (if health data, BAA required) - **PCI DSS** (if payment card data) - **SOX** (if financial reporting data)

6.2 Compliance Provisions Required

- Data Processing Agreement (DPA) for personal data
 - Subprocessor notification and approval rights
 - Right to audit Provider’s compliance
 - Cooperation with regulatory inquiries
 - Data subject request handling within defined SLAs
-

7. AUDIT AND MONITORING RIGHTS

7.1 Example Corp Audit Rights (Mandatory)

- Annual audit right (with 30 days notice)
- Right to engage third-party auditors
- Access to relevant logs, systems, and personnel

- Provider cooperation and documentation provision
 - Remediation of findings within agreed timeframes
-

8. DISPUTE RESOLUTION AND GOVERNANCE

8.1 Acceptable Dispute Resolution

- Governing law: Jurisdiction where **Example Corp is headquartered** or mutually agreed neutral jurisdiction
- Escalation process required before formal proceedings
- Mediation before arbitration or litigation
- If arbitration: neutral arbitration body (AAA, JAMS), arbitrator mutually selected
- Each party bears own costs; loser-pays for frivolous claims only

8.2 Dispute Resolution Red Flags — Flag as HIGH

- Governing law in Provider's jurisdiction exclusively
 - Arbitrator selected solely by one party
 - All costs borne by one party regardless of outcome
 - No escalation or mediation step
 - Venue that creates undue burden on Example Corp
-

9. CONTRACT MODIFICATION PROTECTIONS

9.1 Amendment Requirements

- Amendments require **mutual written consent** signed by authorized representatives of both parties
- No unilateral amendment rights
- Material changes require 30-day review period
- Continued use does not constitute acceptance of unilateral changes

9.2 Amendment Red Flags — Flag as CRITICAL

- Unilateral amendment rights by either party
 - “Continued use equals acceptance” clauses
 - Amendment notice periods under 30 days
 - No signature requirement for changes
-

10. SEVERITY CLASSIFICATION

- **CRITICAL:** Breach notification over 72 hours; indefinite data retention; vague security; unilateral amendments
- **HIGH:** Provider jurisdiction in disputes; no audit rights; no certifications required

- **MEDIUM:** Missing specific encryption standards; DPA not referenced
 - **LOW:** Minor formatting in security exhibit
-

11. AGENT REVIEW INSTRUCTIONS

When reviewing data protection and security terms: 1. Check for specific security standards (not “commercially reasonable”) 2. Verify breach notification is 72 hours or less in clock time 3. Confirm data destruction within 30 days with certification 4. Validate no indefinite retention clauses exist 5. Check that governing law is neutral or Example Corp’s jurisdiction 6. Verify arbitrator/mediator selection is mutual 7. Confirm amendments require mutual written consent 8. Flag any “commercially reasonable” security language as CRITICAL 9. Generate findings referencing specific regulatory requirements where applicable